Honeyrizons · Defense Sheet

Deception for the agentic era: a honeypot that catches the AI agents attacking your infrastructure, proves they are models, and follows them across rotating IPs.

Secure Horizons hackathon · Track 3 Uncharted Frontiers · live at **honeyrizons.xyz** (AWS, Terraform, staging + prod) · 11 Oct 2026

1 · Threat scenario addressed

LLM agents now discover and call tools over the **Model Context Protocol (MCP)**, read files, harvest secrets and exfiltrate with no human in the loop, whether a hijacked developer assistant or an attacker-operated agent. They never replay the same session, rotate botnet/residential IPs and rephrase every call, so IP-, signature- and fingerprint-based defences miss them. An internet-exposed "DevOps assistant" MCP server (shell, files, database, cloud keys) is the new crown-jewel entry point. Their weakness: **they read and obey the text we send back.**

- **Production-looking decoy** (Beelzebub): SSH, Telnet, WordPress, MySQL, Redis, PostgreSQL, Kubernetes API and an MCP server with 5 bait tools returning fake prod data (.env, AWS keys, customer rows, root shell). Every call logged with its arguments.
- **Defensive prompt-injection canary**: a 6th tool, `verify_credentials`, reachable only through text addressed to "AI assistants" (tool description, a line in the fake .env, a note in the cloud-keys response). Scanners don't read prose, humans don't obey it: one call is near-proof a model is driving.
- **Agent score** from 5 behavioural signals (canary, speaks MCP, reuses leaked values, model cadence 0.8-45 s, goal-directed), combined as independent evidence (noisy-OR).
- **Operator correlation** across IPs on what is costly to change: exfil infrastructure, playbook (edit distance), wording (Jaccard), model latency. Output is a **profile, not an attribution**: likely goal + sophistication score, each backed by evidence.
- **Automated triage**: free local rules + LLM analyst (gpt-5.4-nano) give severity, ATT&CK IDs, IOCs and one action per session; campaign fingerprints, 30-min threat brief, event-sourced chronicle that replays the attack surface at any instant.

2 · Use cases covered

Use case	How Honeyrizons covers it
Internal intrusion detection	The same decoys deploy inside the network, where no legitimate host talks to them: any connection is a compromised machine exploring (**T1046**, **T1021**), logged with source IP, credentials and commands. The MCP canary flags a hijacked internal AI agent at its first obeyed instruction.
Threat intelligence	A new technique documented: AI agents attacking over MCP, and how to tell them from scripts. Every session gets ATT&CK IDs, IOCs (payload URLs, dropper commands, credentials, exfil endpoints; never executed) and a recommended detection.
Defense testing	Exposed to the real internet, so the pipeline is tested on live attacks: Redis INFO/PING probes from China, Lithuania, the US and the UK, PostgreSQL probes, zgrab and Palo Alto Xpanse scanners were all logged, triaged and classified, and none was mistaken for an AI agent. A real Claude agent (`attack:claude`) and labelled data measure detection and false positives (section 5).
Shared intelligence	Behaviour fingerprints fold a botnet replaying one script from many IPs into one campaign (486 sessions, 1 analysis) and agents rotating IPs into operators. Verdicts, IOCs and campaigns are served as structured JSON (`/api/intel`) that other organizations can pull.

3 · NIST CSF 2.0 functions covered

Function	Coverage in Honeyrizons
DETECT	**DE.CM-01** continuous monitoring of 8 decoy services, 500 ms log polling, live SSE dashboard · **DE.AE-02** every session analysed automatically · **DE.AE-03** correlation across sessions/IPs (campaigns, operators) · **DE.AE-04** severity estimated per session
RESPOND	**RS.MA-03** sessions categorised and prioritised ("High & critical" filter, "Needs attention") · **RS.AN-03** verdict, IOCs and recommended action · threat brief for the team
IDENTIFY	**ID.RA-02/03** first-hand threat intelligence: who targets which service, operator goals, AI-agent playbooks
PROTECT	Deception diverts attackers to fake assets · secrets in AWS SSM, OIDC CI, read-only log volume · attacker text passed to the LLM as delimited untrusted data
GOVERN	Partial: LLM budget cap (40 calls/h), attacker IP/country never sent to the LLM, explicit no-attribution policy
RECOVER	Out of scope (the decoy holds no real asset)

4 · Techniques and risks addressed

Framework	Techniques / risks
MITRE ATLAS	**AML.T0051.001** indirect prompt injection (turned into a defensive tripwire) · **AML.T0053** AI agent tool invocation · **AML.T0055** unsecured credentials · **AML.T0057** LLM data leakage
MITRE ATT&CK	**T1595** active scanning · **T1110.001/.003** password guessing/spraying · **T1190** exploit public app · **T1082 / T1083** discovery · **T1059.004** Unix shell · **T1552.001** credentials in files · **T1078** valid accounts · **T1098** account manipulation (grant_admin) · **T1021.004** SSH pivot · **T1567 / T1041** exfiltration · **T1496** resource hijacking
OWASP LLM Top 10 (2025)	**LLM01** prompt injection · **LLM06** excessive agency (bait tools an agent should never be granted) · **LLM02** sensitive information disclosure · **LLM10** unbounded consumption (budgeted analyst)

5 · Metrics achieved

Metric	Benchmark: 5 seeded datasets, 1,198 sessions, labelled	Production: honeyrizons.xyz, 10,000 events (11 Oct, 06:04-08:24 UTC)
AI-agent detection	Precision **82%** (138 / 169 flagged sessions are real agents; the other 31 are scripted MCP sweeps). Every agent caught, confidence median 0.84	**2 / 2** red-team agent sessions, confidence 0.99 (canary)
False positives	**0 / 1,029** SSH/HTTP/TCP sessions flagged as agent. Scripted MCP sweeps: 31/31 also flagged (score 0.64)	**0 / 507** non-MCP sessions flagged as agent
Canary trigger	63 / 138 runs (46%; 2 of 4 personas obey by design)	**485** canary calls
Operator correlation	26 clusters for 25 true operators: **100% purity**, 0 merges, 1 split	1 operator, 2 IPs, linked by shared exfil endpoint
Time to detect	Flagged at the **first MCP call** (+<0.5 s ingest); canary proof median **8 s** vs attacker time-to-loot median 11 s	Canary proof **7 s** after the first tool call
Time to respond (triage)	Verdict once the session is quiet 90 s (+10 s tick + LLM call, about 2 min)	503 sessions triaged with 316 verdicts (308 LLM, 8 rules); 486 MySQL sessions folded into 1 campaign; 31/40 LLM calls/h used; 2 high, 199 medium, 115 low

6 · Known limitations

- **Canary not validated on frontier models**: some refuse instructions found in tool output. It is a bonus signal, not the only one.
- **Evasion**: random delays, ignoring unrequested tools and single-use infrastructure weaken cadence and correlation (at a cost in speed and capability). Beelzebub logs no MCP client identity and we have no JA4/User-Agent layer yet.
- **Session windowing** (10 min of silence) merges an always-on agent into one long session (prod: ~850 calls each), which reduces correlation granularity.
- **No automated response**: recommendations only, no blocking or feed export. LLM-assigned ATT&CK names are inconsistent (IDs are fine); analyst capped at 40 calls/h.